

Day117 代码审计-JavaEE开发篇&JDBC拼接 &MyBatis查询&Hibernate模型&SQL预编译制

代码审计-小迪安全



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态

-
- 1、PHP审计-动态调试-变量覆盖
 - 2、PHP审计-动态调试-原生反序列化
 - 3、PHP审计-动态调试-框架反序列化

-
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
 - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞

-
- 1、PHP框架审计-ThinkPHP-反序列化链分析
 - 2、PHP框架审计-ThinkPHP-反序列化链挖掘

-
- 1、PHP框架审计-Yii-反序列化链分析
 - 2、PHP框架审计-Yii-实际CMS挖掘分析

-
- PHP代审项目-TP框架-实战某违法微盘

-
- 1、ASP.NET审计-SQL注入-继承架构&DLL反编译
 - 2、ASP.NET审计-SQL注入-数据库监控&关键字搜索

-
- 1、ASP.NET审计-文件上传-DLL反编译&关键字搜索
 - 2、ASP.NET审计-文件上传-预编译解析&关键字搜索
-

- 1、ASP.NET审计-未授权访问-未引用脆弱鉴权
 - 2、ASP.NET审计-未授权访问-不严谨鉴权逻辑
 - 3、ASP.NET审计-动态调试-附加进程&断点调试
 - 4、ASP.NET审计-程序逆向-EXE逻辑&修改覆盖
-

2.详细点

2.1 代码编辑器

- 
- 1 一、代码编辑器：
 - 2 1.Jetbrains IDEA(IDE)
 - 3 2.Sublime text(文本编辑器)
 - 4 3.Eclipse (IDE)

2.2 测试工具

- 
- 1 1.Burp Suite: 是渗透测试工作者必备的一款工具
 - 2 2.SwitchyOmega: SwitchyOmega 是一款代理管理插件，支持Firefox和Chrome浏览器，并支持HTTP、HTTPS、socket4和socket5协议。
 - 3 3.Max HackerBar: HackBar是的一个插件，也是信息安全从业者常用的经典工具。
 - 4 4.Postman: Postman是一款功能强大的网页调试工具，能够为用户提供强大的Web API & HTTP请求调试功能。
 - 5 5.Ysoserial: 一款开源Java反序列化测试工具，内部集成有多种利用链，可以快速生成用于攻击的代码，也可以将新公开的反序列化漏洞利用方式自行加入Ysoserial中。
 - 6 6.Marshalsec: 是一款开源的Java反序列化测试工具，不仅可以生成各类反序列化利用链，还可以快速启动恶意的RMI服务等。
 - 7 7.MySQL Monitor: 是web版本的SQL记录实时监控工具。
 - 8 8.Beyond Compare: 是一款文件比较工具，主要对比两个文件夹或者文件，并以颜色标示差异，比较范围包括目录、文档内容等。使用该工具可以方便代码审计人员快速地对两个版本代码的差别。

2.3 反编译工具



1. **JD-GUI**: 是一款具有UI界面的反编译工具，界面简洁大方，使用简单方便。
2. **Fernflower**: 功能比JD-GUI更强大，虽然没有UI界面，但可以配合系统指令完成批量反编译的工作。
3. **CFR**: 功能强大的反编译工具，支持主流Java特性——Java 8 lambda表达式，以及Java 7字符串切换。在某些JD-GUI无法反编译的情况下，CFR仍然能完美地进行反编译，也可以像FernFlower那样配合系统指令进行批量反编译。
4. **IntelliJ IDEA**: 具能够自动解包已添加依赖的Jar包，并对其内容进行反编译。该工具拥有动态调试和字符串匹配和搜索功能，为审计和调试漏洞工作提供了极大便利。
5. **CodeReviewTools**: 是一款可以快速搜索代码中的关键点，一键对jar进行批量反编译，也支持直接对war包进行操作。

2.4 Java代码静态扫描工具



1. **Fortify SCA**: 获得业界认可的静态代码检查工具，但它是收费的。Fortify SCA的核心在于规则库，用户可以自定义规则库，减少误报。
2. **VCG**: 基于 VB 开发的一款Windows下的白盒审计工具。VCG 支持多种语言，例如C/C++、Java、C#、VB、PL/SQL、PHP。VCG会根据代码中的变量名等信息动态生成针对该代码的漏洞规则，通过正则检查是否有和漏洞规则所匹配的代码。
3. **FindBugs与FindSecBugs插件**: FindBugs是一款Bug扫描插件，在IDEA和Eclipse中都可进行安装。FindBugs可以帮助开发人员发现代码缺陷，减少Bug，但其本身并不具备发现安全漏洞的能力，需要安装FindSecBugs拓展发现安全漏洞的能力。
4. **SpotBugs**: 是FindBugs的继任者，所以二者用法基本一样，可以独立使用，也可以作为插件使用。
5. **CheckMark**: 白盒代码审计解决方案，主要通过采用独特的词汇分析技术和CXQL专利查询技术对应用程序源码进行静态分析检查。
6. **Snyk插件**: 修复项目中的安全漏洞、基础架构错误配置和代码质量问题。
7. **Sensei插件**: 可在键入时扫描和修复易受攻击的代码 - 具有数百个可下载的安全编码配方（规则）以及内置的自行制作能力。
8. **Reshift Security插件**: 可以快速发现漏洞，提供多个代码修复片段，以及丰富的文档，涵盖了每个漏洞的检测、修复和测试。
9. **MurphySec Code Scan插件**: 可以快速识别您的项目中使用了哪些存在安全缺陷的开源组件，并帮助您一键修复问题。
10. **Momo Code Sec Inspector插件**: 重于在编码过程中发现项目潜在的安全风险，并提供一键修复能力。
11. **dependence-check**: 可用于检查已发布安全漏洞的项目依赖项。
12. **wJa**: 一款结合DAST、SAST、IAST的综合性应用程序安全分析工具，支持对java web程序的安全性进行分析，含有反编译，代码审计，调试jar包，代理追踪等用于分析软件安全的功能。
13. **tabby**: 是一款针对Java语言的静态代码分析工具，它使用静态分析框架 Soot 作为语义提取工具，将JAR/WAR/CLASS文件转化为代码属性图，并使用 Neo4j 图数据库来存储生成的代码属性图CPG。
14. **SpringInspector**: Java自动代码审计工具，尤其针对Spring框架，提供一个SpringBoot的Jar包即可进行自动代码审计，底层技术基于字节码分析。
15. **gadgetinspector**: 反序列化漏洞利用链、漏洞检测工具。

2.5 开发审计入口常见方法



- 1 -搜索法：常规或部分MVC模型源码可以采用关键字的搜索挖掘思路
- 2 -功能法：框架MVC模型源码一般会采用功能点分析抓包追踪挖掘思路
- 3 -对比法：可以通过前后修复版本文件及代码不同特征进行针对挖掘思路
- 4 -特征法：数据库监控SQL注入，文件监控挖上传删除写入等，后续补充
- 5 -调试法：动态调试（PHP,ASP.NET,JavaEE,Python等）
- 6 -工具法：后续讲到（DAST&SAST&IAST&CodeQL等）

2.6 SQL注入分析



- 1 1、三个模式：
- 2 JDBC, Mybatis, Hibernate



- 1 2、出现注入：
- 2 原生JDBC是否存在直接拼接SQL语句（使用+，或者使用StringBuilder append()），未经过预编译；
- 3 Mybatis使用\${}；
- 4 Hibernate、JPA默认是经过预编译的，但是如果开发自己编写的SQL语句，也需要进行检查；
- 5 Java是强类型语言，当注入参数为long、int等数字类型时无法进行注入；
- 6 找到危险函数位置之后，向上搜索，找函数、方法调用位置，直到请求入口（controller层），判断是否存在无害化处理、无害化处理是否严格；
- 7 参考：<https://mp.weixin.qq.com/s/9t3t6qxosGskIXMIRtMoPw>



- 1 3、判断模式：
- 2 -看项目说明使用的技术框架
- 3 -看引用中加载那些技术框架
- 4 -看配置源码中相关配置文件



- 1 4、入口确定：
- 2 1、是否使用预编译技术，预编译是否完整。
- 3 2、定位SQL语句上下文，查看是否有参数直接拼接，是否有对模糊查询关键字的过滤。
- 4 3、Mybatis框架则搜索\${}，四种情况无法预编译：like模糊查询、order by排序、范围查询in、动态表名/列名，只能拼接，所以还是需要手工防注入，此时可查看相关逻辑是否正确。
- 5 4、JPA搜索JpaSort.unsafe()，查看是否用实体之外的字段对查询结果排序，进行了SQL的拼接。以及查看EntityManager的使用，也可能存在拼接SQL的情况。



- 1 Statement
- 2 createStatement
- 3 PrepareStatement
- 4 like '%\${
- 5 in(\${

```
6  in (${
7  select
8  update
9  insert
10 delete
11 ${
12 order by
13 setObject(
14 setInt(
15 setString(
16 setSQLXML(
17 createQuery(
18 createSQLQuery(
19 createNativeQuery
20 .....
```

3.演示案例

3.1 JavaEE审计-SQL注入-JDBC&JFinal_CMS

```
1 案例1-非框架JDBC-Jfinal_cms论坛系统
2 https://github.com/jflyfox/jfinal\_cms
3 分析: 确定非框架->搜关键字order by append->getBaseForm()->getOrderBy()->getOrderColumn-
  >orderColumn
4 路由: Post: /admin/advicefeedback/list
5 参数: form.orderColumn
6 拼接: order by ").append(orderBy);
7 POC: ' xxx #(直接sqlmap搜哈)
```

3.2 JavaEE审计-SQL注入-MyBatis&Oasys&Ruoyi

```
1 案例2-SpringBoot+Mybatis-Oasys办公系统
2 https://gitee.com/aaluoxiang/oa\_system
3 分析: 确定Mybatis框架->搜关键字${->%${baseKey}%->sortMyNotice->sortMyNotice-
  >informListPaging->
4 路由: Post: /informlistpaging
5 参数: baseKey
6 拼接: and n.title LIKE '%${baseKey}%'
7 POC: ' xxx #(直接sqlmap搜哈)
```



```
1  案例3-SpringBoot+Mybatis-Ruoyi若依系统 V4.6
2  https://gitee.com/y_project/RuoYi
3  基于springboot中，执行SQL三个调用：
4  1、业务层调用dao层
5  2、controller调用Service层间接调用dao层
6  3、controller直接调用dao层
7  分析：确定Mybatis框架->搜关键字${->updateDeptStatus->updateParentDeptStatus->updateDept-
   >editSave
8  路由：Post: /system/dept/edit
9  参数：ancestors
10  拼接：where dept_id in (${ancestors})
11  POC:
    DeptName=1&DeptId=100&ParentId=12&Status=0&OrderNum=1&ancestors=0)or(extractvalue(1,co
    ncat((select user()))));#
```

3.3 JavaEE审计-SQL注入-Hibernate&lcmsNewsfu